COMPTIA SECURITY+ SY0-701 DOMÍNIO 1 · CONCEITOS GERAIS DE SEGURANÇA (12%)

Security+ 1.4 · Encryption Technologies

Mestre CyberSec · **Aula 1.4 — Encryption Technologies** (6:53) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Hardware de criptografia: TPM (chip na placa-mãe, mede o boot — base do BitLocker); HSM (appliance dedicado pra gerir chaves de alto valor — banco/governo); Secure Enclave (área isolada do CPU iOS); SED (self-encrypting drive: disco que cifra sozinho).

💡 Highlights que a prova CompTIA cobra

- TPM = Trusted Platform Module — chip físico; mede boot + guarda chave
- HSM = Hardware Security Module — dedicado pra chave de alto valor
- Secure Enclave: processador segregado (Apple) pra biometria/pagamento

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'chip on the motherboard that measures boot process' = TPM
- 'dedicated appliance for cryptographic key operations' = HSM

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.4 — Encryption Technologies)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Trusted Platform Module (Módulo de Plataforma Confiável) (TPM)

Um chip criptográfico dedicado soldado na placa-mãe que armazena chaves de criptografia (como a chave mestra do BitLocker) e realiza medições de integridade do processo de boot para detectar adulterações.

⚠️ ***Armadilha CompTIA:*** *Gatilho clássico: 'chip on the motherboard that measures boot' = TPM. Sempre. Se a pergunta diz 'chip físico na placa-mãe + boot + chaves', não confunda com HSM (que é appliance externo) nem Secure Enclave (que é CPU isolado, não chip separado).*

• Hardware Security Module (Módulo de Segurança de Hardware) (HSM)

Um appliance físico, resistente a violação, dedicado a gerar, armazenar e gerenciar chaves criptográficas de alto valor, comumente usado por bancos, autoridades certificadoras e ambientes governamentais.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'dedicated appliance for cryptographic key operations', 'high-value keys', 'PKI root key storage' = HSM. Distinção crítica: TPM é chip interno de um único PC; HSM é appliance de rede para muitas chaves de missão crítica.*

• Secure Enclave (Ambiente Seguro) (SE)

Um subsistema isolado em hardware dentro do SoC de dispositivos Apple iOS/macOS que processa Touch ID, Face ID e chaves do Apple Pay separadamente do processador principal de aplicações.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'isolated processor area on iOS', 'Apple biometric security', 'separate from main CPU' = Secure Enclave. Não confunda com TPM — TPM é chip na placa-mãe; Secure Enclave é região segregada dentro do mesmo chip SoC da Apple.*

• Self-Encrypting Drive (Disco Auto-Criptografado) (SED)

Um disco rígido ou SSD com hardware de criptografia integrado que cifra todos os dados no meio automaticamente, sem impacto de performance e de forma transparente para o sistema operacional.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'disk that encrypts itself', 'hardware-based full-disk encryption', 'no CPU performance impact' = SED. Cuidado: BitLocker é software (usa CPU); SED é o próprio disco fazendo a cifra em hardware — perguntas podem comparar as duas abordagens.*

• BitLocker (N/A)

Recurso de criptografia de disco completo do Microsoft Windows que usa um TPM para vincular a chave de criptografia ao hardware, impedindo o acesso aos dados se o disco for movido para outro computador.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'Windows full-disk encryption + TPM' = BitLocker. Relação de prova: BitLocker SEM TPM = funciona com PIN USB, mas é menos seguro; COM TPM v1.2+ = Measured Boot ativo. Tied to hardware é a frase-chave da questão.*

• Measured Boot (Boot Medido) (N/A)

Recurso do TPM que aplica hash nos componentes de boot (BIOS, bootloader, kernel do SO) nos Platform Configuration Registers (PCRs) para detectar qualquer adulteração na cadeia de boot antes de liberar a chave de criptografia do disco.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'TPM measures boot integrity', 'PCR registers', 'verifies boot chain has not been tampered' = Measured Boot. Diferencie de Secure Boot (UEFI que bloqueia componentes não assinados) — Measured Boot apenas registra hashes, não bloqueia.*

• Key Escrow (Custódia de Chaves) (N/A)

Arranjo de gerenciamento de chaves criptográficas no qual cópias de chaves privadas são mantidas por um terceiro confiável, permitindo recuperação dos dados criptografados caso a chave original seja perdida.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'third party holds copy of encryption key', 'key recovery', 'business continuity for encrypted data' = Key Escrow. Contexto de prova: governos/empresas usam escrow para garantir recuperação; questão pode contrastar com HSM, que é para chaves vivas, não backup.*

• Platform Configuration Registers (Registradores de Configuração da Plataforma) (PCR)

Locais de memória dentro do TPM que armazenam medições de hash dos componentes de boot durante o Measured Boot, usados para verificar a integridade da cadeia de boot antes de liberar as chaves de criptografia.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'TPM stores boot hashes', 'PCR values', 'attestation' = Platform Configuration Registers. Termo técnico raro na prova, mas aparece em cenários avançados de TPM e BitLocker — relacione sempre com Measured Boot, nunca isolado.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Criptografia Simétrica (AES) vs. Assimétrica (RSA/ECC)

🏠 **Analogia Intuitiva:** Pense na fechadura física da sua casa vs. a caixa de correio da calçada. A Criptografia Simétrica (como AES) é uma chave única de latão: ela tranca a porta da frente e abre a porta da frente com extrema rapidez e facilidade. Mas se você quiser dar acesso a um amigo que mora no Japão, você tem um problema insolúvel: como enviar essa chave de latão até lá sem que ninguém copie? A Criptografia Assimétrica (como RSA ou Curvas Elípticas) é como uma caixa de correio fixada no portão: ela tem uma ranhura aberta pública onde qualquer pessoa que passa na calçada pode jogar uma carta (a Chave Pública), mas apenas você tem a chave de metal exclusiva para abrir a portinhola traseira e recolher a correspondência (a Chave Privada).

🔍 **Causa Raiz / Por que foi criado:** A criptografia simétrica é ordens de grandeza mais rápida e computacionalmente leve, sendo ideal para grandes volumes de dados (streaming, bancos de dados, discos rígidos). Porém, ela sofre com o pesadelo da distribuição de chaves (para N pessoas se comunicarem em pares seguros, são necessárias N*(N-1)/2 chaves). A assimétrica resolve a distribuição de chaves através de pares matematicamente correlacionados, mas é centenas de vezes mais lenta.

🛡️ **Visão do Auditor de GRC:** Estabelecer uma política criptográfica formal alinhada ao NIST SP 800-175B. O auditor de GRC fiscaliza se dados corporativos em repouso são protegidos exclusivamente com AES-256 ou AES-128 (proibindo DES, 3DES e RC4) e verifica se chaves assimétricas RSA possuem no mínimo 2048 bits (recomendado 3072+) ou curvas elípticas de pelo menos 256 bits.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'single shared key used for both encryption and decryption with high speed' -> Symmetric encryption (AES); 'uses a public key to encrypt and a private key to decrypt' -> Asymmetric encryption (RSA/ECC).

📌 Criptografia Híbrida: O Envelope Digital

🏠 **Analogia Intuitiva:** Imagine que você precisa enviar um caminhão carregado com 20 toneladas de mercadorias valiosas (seus arquivos pesados). Você não vai trancar o caminhão inteiro com um cadeado assimétrico lento de 4096 bits, pois o motor nem conseguiria rodar. Em vez disso, você tranca a porta do caminhão com um cadeado comum de aço rápido e barato (a chave simétrica AES daquela viagem). Em seguida, você coloca essa chave de latão dentro de um envelope timbrado blindado e lacra o envelope com o selo público do destinatário (a chave pública assimétrica RSA). O mensageiro leva o envelope rapidamente. O destinatário abre o envelope com sua chave privada, retira a chave de latão e destranca o caminhão em segundos! Você obteve o melhor dos dois mundos: a velocidade do caminhão e a segurança do envelope.

🔍 **Causa Raiz / Por que foi criado:** A criptografia assimétrica pura é computacionalmente proibitiva para grandes volumes de dados. Toda a segurança da internet moderna (como HTTPS/TLS, PGP/GPG e SSH) é implementada sob a forma de sistemas híbridos: algoritmos assimétricos são usados apenas nos primeiros milissegundos para autenticar e trocar com segurança a chave simétrica efêmera que cifrará os dados reais.

🛡️ **Visão do Auditor de GRC:** Garantir que os serviços e produtos de software da organização utilizem padrões de envelopes digitais consolidados e testados (como CMS / PKCS#7 ou OpenPGP). O auditor deve validar que as chaves de sessão simétricas geradas sejam descartadas da memória volátil imediatamente após o encerramento da conexão.

> ⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'combines the speed of symmetric encryption with the key-exchange benefits of asymmetric encryption' -> Hybrid cryptography (Digital Envelope); 'used in PGP, S/MIME, and TLS to protect bulk transmission' -> Hybrid encryption.

📌 Hardware Criptográfico: TPM (Trusted Platform Module) vs. HSM (Hardware Security Module)

🏠 **Analogia Intuitiva:** Pense no cadeado imobilizador embutido no motor do seu carro vs. a sala-cofre blindada do Banco Central. O TPM (Trusted Platform Module) é o chip sentinela soldado diretamente na placa-mãe do seu notebook de trabalho: ele guarda a chave do BitLocker e realiza a 'Inicialização Medida' (Measured Boot), conferindo se ninguém adulterou o sistema operacional antes de dar a partida. O HSM (Hardware Security Module) é um aparelho de rack de alta segurança, que custa dezenas de milhares de dólares e fica trancado em datacenters bancários: ele gerencia milhões de chaves de transações PIX/cartão e chaves de Root CA, possuindo blindagem física contra arrombamento (se alguém tentar perfurar a carcaça com furadeira ou raio-x, ele apaga todas as chaves instantaneamente por autodestruição).

🔍 **Causa Raiz / Por que foi criado:** Armazenar chaves criptográficas em arquivos no disco rígido ou na memória RAM comum expõe a empresa a malwares com privilégios de administrador ou roubo físico de equipamentos. O hardware dedicado cria uma barreira física e criptográfica impenetrável onde as chaves são geradas, armazenadas e utilizadas sem nunca saírem do chip para a memória do computador.

🛡️ **Visão do Auditor de GRC:** Fiscalizar o parque de endpoints corporativos exigindo a presença e ativação obrigatória do TPM 2.0 (baseline de conformidade para Windows 11 e BitLocker). Em ambientes corporativos de CA ou sistemas de pagamento, auditar se os HSMs possuem certificação FIPS 140-2 / 140-3 Nível 3 ou 4 (exigência do PCI-DSS para custódia de chaves de criptografia de PIN e chaves de CA Raiz).

> ⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'microchip soldered onto the motherboard providing hardware-based key storage and measured boot' -> TPM (Trusted Platform Module); 'dedicated enterprise physical appliance used to securely generate, store, and manage CA and payment keys' -> HSM (Hardware Security Module).

📌 Curvas Elípticas (ECC) vs. RSA

🏠 **Analogia Intuitiva:** Pense em duas fechaduras de altíssima segurança: uma fechadura de castelo medieval com uma chave de ferro maciço de meio metro de comprimento (RSA) vs. uma fechadura eletrônica biométrica de titânio do tamanho de uma moeda (ECC). Para oferecer uma proteção militar impenetrável contra computadores modernos, o RSA precisa de uma chave gigantesca de 4096 bits (que consome muita bateria e processamento em smartphones e sensores de IoT). As Curvas Elípticas (ECC) atingem o mesmo nível exato de segurança com uma chave compacta de apenas 256 bits! É como ter a mesma resistência de uma porta de cofre de banco usando um chaveiro fino que cabe no bolso de uma calça jeans.

🔍 **Causa Raiz / Por que foi criado:** O RSA baseia-se na dificuldade de fatorar o produto de números primos gigantescos. Com os avanços matemáticos dos algoritmos de fatoração, o tamanho das chaves RSA precisa dobrar e triplicar para manter o nível de segurança. A geometria das Curvas Elípticas (baseada no problema do logaritmo discreto em curvas) oferece uma resistência exponencialmente maior por bit de chave.

🛡️ **Visão do Auditor de GRC:** Recomendar em relatórios de auditoria a transição gradual de certificados legados RSA 2048 para ECDSA / ECC em dispositivos móveis, frotas de sensores IoT e cartões inteligentes. Isso reduz consumo de banda de rede, latência em handshakes TLS e economia de energia sem comprometer requisitos de compliance.

⚠️ **Como cai na Prova CompTIA:** Gatilhos da prova: 'asymmetric algorithm that provides equivalent cryptographic strength to RSA using significantly smaller key sizes' -> Elliptic Curve Cryptography (ECC); 'best asymmetric encryption option for resource-constrained devices, smart cards, or mobile phones' -> ECC.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Padrão de criptografia simétrica de alto desempenho utilizado pelo governo dos EUA e bancos para dados em repouso	**AES (Advanced Encryption Standard)**
Combinação de cifra assimétrica para troca rápida de chave com cifra simétrica para o volume de dados	**Criptografia Híbrida (Envelope Digital)**
Microchip soldado na placa-mãe do computador que armazena chaves de disco e valida a integridade do boot	**TPM (Trusted Platform Module)**
Appliance físico corporativo dedicado com blindagem anti-violação para geração e custódia de chaves de CA e financeiras	**HSM (Hardware Security Module)**
Criptografia assimétrica ideal para celulares e IoT por atingir alta segurança com chaves muito menores que RSA	**ECC (Elliptic Curve Cryptography)**
Disco rígido corporativo que realiza a criptografia automática de todo o armazenamento em nível de hardware	**SED (Self-Encrypting Drive)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um técnico removeu um disco NVMe de um notebook protegido pelo BitLocker e o conectou a outra estação de trabalho no laboratório. O disco foi detectado, mas os dados estavam ilegíveis e apareceu um aviso de recuperação. Qual componente de hardware foi o principal responsável por selar a chave mestra do volume de modo que ela só pudesse ser liberada para o estado de boot íntegro daquele notebook específico?

A) O Trusted Platform Module (TPM) na placa-mãe do notebook original, que selou a chave a valores específicos dos Platform Configuration Registers

B) Um Hardware Security Module (HSM) conectado à rede que guardava a chave de criptografia de mídia do volume

C) O Secure Enclave na CPU do notebook, que envolveu a chave com o template biométrico do usuário

D) Um controlador SED compatível com OPAL que armazenou a chave de criptografia de mídia em uma área de serviço oculta no disco

QUESTÃO 2 · CENÁRIO DE EXAME

Uma instituição financeira opera uma autoridade certificadora interna que assina certificados para sua rede de pagamentos. Os auditores exigem que a chave privada da CA raiz seja gerada e usada dentro de um appliance dedicado e resistente a violação, que realize operações de assinatura sem nunca expor o material da chave, e que o dispositivo seja validado no nível 3 do FIPS 140-2. Qual solução atende MELHOR a esse requisito?

A) Habilitar TPM 2.0 na placa-mãe do servidor da CA e selar a chave raiz às medições de boot

B) Um keystore de software criptografado com AES-256 no servidor da CA, com arquivo de chave privada protegido por senha

C) Um appliance Hardware Security Module (HSM) dedicado, com invólucro sensível a violação e ativação de chave M-de-N

D) Um Secure Enclave integrado ao processador de aplicação do servidor da CA para operações isoladas de chave

QUESTÃO 3 · CENÁRIO DE EXAME

Um aplicativo de banco móvel precisa armazenar a chave privada usada para autorizar transações de modo que ela não possa ser extraída nem se o kernel do sistema operacional for totalmente comprometido por malware. Os desenvolvedores querem que a chave seja gerada e usada dentro de uma área de hardware dedicada e isolada do processador do dispositivo, separada do ambiente de execução da CPU principal. Em qual tecnologia eles devem confiar?

A) TPM 2.0 com Platform Configuration Registers vinculados à cadeia de boot

B) Um disco auto-criptográfico OPAL que criptografa o sandbox da aplicação

C) Um HSM conectado à rede, acessado via TLS a partir do celular

D) O Secure Enclave, um ambiente de execução isolado no SoC do dispositivo

QUESTÃO 4 · CENÁRIO DE EXAME

Um projeto de renovação de hardware exige criptografia de disco completo em 2.000 estações de trabalho de engenharia que executam cargas intensivas de CPU. A equipe quer que a criptografia seja tratada pelo próprio controlador do disco, para que a CPU hospedeira não sofra sobrecarga mensurável de criptografia, e que os dados permaneçam cifrados sempre que o disco perder energia. Qual tecnologia atende MELHOR a isso?

A) BitLocker em modo de criptografia de software usando AES-XTS na CPU hospedeira

B) Um disco auto-criptográfico (SED) com controlador compatível com OPAL

C) Um Hardware Security Module instalado em cada estação de trabalho

D) O Secure Enclave da CPU realizando criptografia de disco em linha

QUESTÃO 5 · CENÁRIO DE EXAME

Depois que a TI enviou uma atualização de firmware UEFI para uma frota de notebooks protegidos pelo BitLocker, dezenas de usuários foram solicitados a inserir sua chave de recuperação do BitLocker de 48 dígitos no boot seguinte, embora não tivessem alterado nenhuma senha. Qual é a causa MAIS provável?

A) A chave raiz de armazenamento do TPM foi excluída quando o disco foi reimplantado

B) O controlador do SED rotacionou sua chave de criptografia de mídia após a atualização

C) Os hashes de boot medidos registrados nos Platform Configuration Registers do TPM mudaram, então o TPM deixou de liberar a chave mestra de volume selada

D) O banco de dados de custódia de chaves perdeu as senhas de recuperação daquelas máquinas

QUESTÃO 6 · CENÁRIO DE EXAME

A equipe jurídica de uma empresa precisa conseguir ler o conteúdo do notebook criptografado de um funcionário que está saindo, para preservar evidências. Os notebooks usam BitLocker, e a TI configurou Diretiva de Grupo para que as senhas de recuperação sejam armazenadas centralmente no serviço de diretório no momento da criptografia. Qual conceito essa configuração implementa?

A) Atestação remota da cadeia de boot

B) Selagem da chave mestra de volume por PCR

C) Apagamento criptográfico por meio de rotação da chave de mídia

D) Custódia de chaves (key escrow), em que chaves de recuperação são armazenadas centralmente para recuperação autorizada

QUESTÃO 7 · CENÁRIO DE EXAME

Uma arquitetura Zero Trust exige que, antes de um endpoint remoto poder entrar na VPN corporativa, o sistema de controle de acesso à rede verifique que a cadeia de boot do endpoint não foi adulterada. O TPM do endpoint armazena hashes de firmware e componentes de boot em PCRs e pode produzir um quote assinado desses valores para o servidor comparar com uma linha de base confiável. Como essa capacidade é chamada?

A) Atestação remota baseada em boot medido

B) Custódia de chaves com recuperação lastreada em hardware

C) Bloqueio de disco auto-criptográfico via segurança ATA

D) Validação FIPS 140-2 nível 3 do endpoint

QUESTÃO 8 · CENÁRIO DE EXAME

Um processador de pagamentos precisa proteger a chave mestra que descriptografa dados de portadores de cartão em milhares de transações por segundo. A política exige que a chave nunca saia do limite de hardware, que nenhum administrador sozinho possa ativá-la e que o dispositivo zeroíze suas chaves se o invólucro for aberto. Qual controle se encaixa MELHOR?

A) TPM 2.0 no servidor de transações, selando a chave mestra aos PCR 0-7

B) Um Secure Enclave na CPU do servidor de transações com ativação biométrica

C) Um appliance HSM reforçado, com invólucro sensível a violação e autenticação por quórum M-de-N

D) Um keystore de software protegido por uma chave AES-256 derivada de senha

QUESTÃO 9 · CENÁRIO DE EXAME

Uma organização quer proteção de chaves do BitLocker lastreada em hardware e verificação de integridade de boot em 5.000 notebooks, mas o orçamento permite apenas um pequeno chip criptográfico por dispositivo, soldado à placa-mãe, sem appliance dedicado por usuário. Qual tecnologia atende ao requisito?

A) Um cluster de HSMs conectados à rede e compartilhados por todos os notebooks

B) Um chip TPM 2.0 integrado à placa-mãe de cada notebook

C) Um Secure Enclave na GPU dedicada de cada notebook

D) Um controlador SED OPAL com servidor externo de gestão de chaves

QUESTÃO 10 · CENÁRIO DE EXAME

Um hospital está desativando 300 notebooks que contêm SEDs. Os discos serão reutilizados em outro departamento, sem necessidade de reter os dados antigos, e a equipe de segurança quer que os dados antigos se tornem permanentemente irrecuperáveis em segundos, sem sobrescrever o disco inteiro. Qual é a ação MAIS apropriada?

A) Realizar um apagamento criptográfico, fazendo o controlador do disco regenerar e destruir sua chave de criptografia de mídia

B) Executar uma sobrescrita de passagem única em todos os setores com dados aleatórios

C) Desmagnetizar o disco para perturbar os domínios magnéticos

D) Limpar o TPM e excluir a senha de recuperação do BitLocker do diretório

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — O Trusted Platform Module (TPM) na placa-mãe do notebook original, que selou a chave a valores específicos dos Platform Configuration Registers

O TPM sela a chave mestra de volume do BitLocker a valores específicos de PCR que representam o estado de boot medido da plataforma original. Ao mover o disco para outro computador, as medições de PCR diferem, o TPM se recusa a desselar a chave e o BitLocker exibe o prompt de recuperação. Um HSM é um appliance centralizado usado para chaves de alto valor, não para selagem de BitLocker por notebook; o Secure Enclave é uma área isolada de SoC móvel e não protege volumes BitLocker do Windows; um SED OPAL armazena sua própria chave de mídia, mas a vinculação às medições de boot de uma máquina específica é feita pelo TPM.

Questão 2: Alternativa C — Um appliance Hardware Security Module (HSM) dedicado, com invólucro sensível a violação e ativação de chave M-de-N

Um HSM é projetado especificamente para gerar, armazenar e usar chaves criptográficas de alto valor dentro de um limite reforçado, executando operações de assinatura internamente para que as chaves nunca saiam do módulo. Invólucros sensíveis a violação, zeroização e ativação por múltiplas pessoas (M-de-N) atendem às expectativas do FIPS 140-2 nível 3. Um TPM é projetado para proteger chaves de uma única plataforma e não é qualificado para custódia de chave raiz de CA multi-inquilino; um keystore de software expõe chaves à memória e a malware; o Secure Enclave existe em projetos móveis/SoC e não é um appliance de CA nível 3 autônomo.

Questão 3: Alternativa D — O Secure Enclave, um ambiente de execução isolado no SoC do dispositivo

O Secure Enclave é um núcleo de processador separado e isolado dentro do SoC, que executa seu próprio microkernel e armazena chaves em hardware dedicado, de modo que nem mesmo um kernel do SO totalmente comprometido consegue ler o material da chave. TPMs normalmente estão em PCs e servidores e fornecem medição de plataforma e selagem de chaves, não isolamento de chaves em nível de aplicativo móvel; SEDs criptografam volumes inteiros e não têm isolamento de chave em nível de aplicação; um HSM remoto poderia assinar no lugar do dispositivo, mas o requisito aqui é isolamento no próprio aparelho móvel.

Questão 4: Alternativa B — Um disco auto-criptográfico (SED) com controlador compatível com OPAL

Um disco auto-criptográfico realiza criptografia e descriptografia AES no próprio controlador do disco, de modo que a CPU hospedeira não paga custo mensurável de criptografia, e a chave de criptografia de mídia permanece no disco, garantindo que os dados em repouso estejam sempre cifrados quando sem energia. O modo software do BitLocker consome ciclos da CPU hospedeira; um HSM é um appliance de gestão de chaves, não um motor de criptografia de disco; o Secure Enclave é um ambiente isolado móvel/SoC e não realiza criptografia de disco completo em estações de trabalho.

Questão 5: Alternativa C — Os hashes de boot medidos registrados nos Platform Configuration Registers do TPM mudaram, então o TPM deixou de liberar a chave mestra de volume selada

O BitLocker sela a chave mestra de volume a valores de PCR que contêm hashes do firmware e dos componentes de boot. Uma atualização de firmware UEFI altera essas medições, então os valores de PCR não correspondem mais ao estado selado e o TPM retém a chave, acionando o modo de recuperação. Reimagem ou TPM limpo seriam causas-raiz diferentes (e afetariam todo o ciclo de vida do disco); a rotação de chave do SED não dispara prompts de recuperação do BitLocker; uma senha de custódia perdida impediria a recuperação, não causaria o prompt.

Questão 6: Alternativa D — Custódia de chaves (key escrow), em que chaves de recuperação são armazenadas centralmente para recuperação autorizada

Armazenar senhas de recuperação do BitLocker no Active Directory (ou outro repositório gerenciado) é custódia de chaves (key escrow): uma cópia da chave de recuperação é mantida por um terceiro confiável para que pessoal autorizado possa recuperar o acesso quando o caminho normal de desselagem falha. Atestação remota valida a integridade do boot, a selagem por PCR é o que vincula a chave à plataforma, e o apagamento criptográfico destrói a chave de mídia — nenhum desses descreve o armazenamento central de chaves de recuperação.

Questão 7: Alternativa A — Atestação remota baseada em boot medido

O boot medido registra hashes de firmware, bootloader e componentes do SO nos PCRs, e a atestação remota usa um quote assinado pelo TPM desses valores de PCR para que a parte confiante confirme que o endpoint inicializou uma configuração não adulterada antes de conceder acesso. A custódia de chaves armazena chaves de recuperação; a segurança ATA bloqueia o disco, mas não prova a integridade do boot a um servidor remoto; o FIPS 140-2 é um padrão de validação de módulos criptográficos, não um mecanismo de atestação de integridade de boot.

Questão 8: Alternativa C — Um appliance HSM reforçado, com invólucro sensível a violação e autenticação por quórum M-de-N

Um appliance HSM é projetado para manter chaves de alto valor dentro de um limite de hardware sensível a violação, zeroizar em caso de intrusão e suportar ativação por quórum com conhecimento dividido (M-de-N), de modo que nenhum administrador isolado possa usar a chave. Um TPM sela chaves a medições de plataforma, mas não é feito para custódia central de chaves de alto throughput nem controles de quórum; o Secure Enclave é um ambiente isolado no SoC para uso móvel/desktop; um keystore de software mantém chaves em memória, violando o requisito de 'nunca sair do limite de hardware'.

Questão 9: Alternativa B — Um chip TPM 2.0 integrado à placa-mãe de cada notebook

O TPM é exatamente esse pequeno chip criptográfico soldado à placa-mãe; ele mede o processo de boot nos PCRs e sela chaves como a chave mestra de volume do BitLocker, fornecendo tanto proteção de chaves quanto verificação de integridade de boot por dispositivo. Um HSM de rede é um appliance centralizado e não faz medição de boot por dispositivo; o Secure Enclave não é implementado em GPUs dedicadas nem usado para BitLocker; um SED criptografa o disco, mas não realiza medição de boot de plataforma para o BitLocker.

Questão 10: Alternativa A — Realizar um apagamento criptográfico, fazendo o controlador do disco regenerar e destruir sua chave de criptografia de mídia

Em um disco auto-criptográfico, todos os dados são cifrados sob uma chave de criptografia de mídia mantida pelo controlador. Regenerar ou destruir essa chave (apagamento criptográfico) torna o texto cifrado permanentemente indecifrável em segundos e é o método padrão de sanitização para SEDs. Uma sobrescrita completa é lenta e desnecessária; desmagnetizar destrói o disco e é pouco confiável para SSDs; limpar o TPM e excluir a senha de recuperação não remove os dados, pois o SED ainda mantém sua própria chave de mídia e o texto claro permanece legível.